



FUNDAMENTAL OF SOFTWARE SECURITY

Alemu Woldie

awcourseapp@gmail.com
Software Engineering
Wolkite, Ethiopia

Chapter Two - Secure Models & Design Principles

After completing this chapter, You're expected to:

- Understand the two fundamental network security models
- Know the core security requirements and their implementations
- Apply secure design principles in software development
- Assess risks and implement appropriate mitigation techniques
- Understand threat modeling and secure architecture tenets

Why Security Models Matter

Purpose of Security Models

Provide structured frameworks for understanding, designing, and implementing security measures in networked environments

- **Systematic Approaches:** Enable consistent implementation across systems
- **Early Requirements Identification:** Help identify security needs during design phase
- **Risk Management Support:** Facilitate assessment and mitigation strategies
- **Communication Framework:** Standard language for discussing security concerns

Key Insight

Models transform abstract security concepts into implementable design patterns

General Model for Network Security

- A message is to be transferred from one party to another across some sort of Internet service.
- The two parties must cooperate for the exchange to take place.
- A logical information channel is established by defining routes & communication protocols by the principals.
- Security aspects come into play when it is necessary to protect the information transmission from an opponent.
- All the techniques for providing security have two components:
 - A security-related transformation on the information to be sent
 - Some secret information shared by the two principals

General Model for Network Security

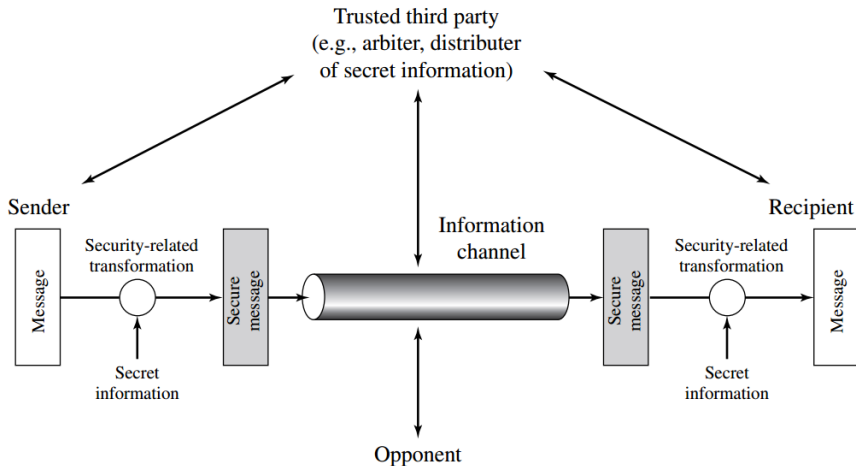


Figure 1: Model for Network Security

Four Design Tasks

- The general model shows that there are four basic tasks in designing a particular security service:
 - ① Design an algorithm for performing the security-related transformation.
 - ② Generate the secret information to be used with the algorithm.
 - ③ Develop methods for the distribution and sharing of the secret information.
 - ④ Specify protocols to be used by principals that makes use of the security algorithm & secret information.

Trusted Third Party

May be needed to achieve secure transmission:

- Responsible for distributing secret information while keeping it from opponents
- Arbitrate disputes between principals concerning message authenticity

Network Access Security Model

- There are other security-related situations of interest that do not neatly fit the general model
- This model reflects a concern for protecting an information system from unwanted access.

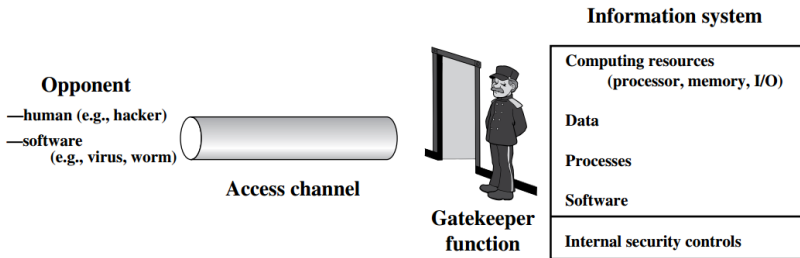


Figure 2: Network Access Security Model

Types of Threats

- Most users are familiar with the concerns caused by the existence of hackers, who attempt to penetrate systems that can be accessed over a network.
- The hacker can be someone who, with no malign intent, simply gets satisfaction from breaking and entering a computer system.
- The intruder can be a disgruntled employee who wishes to do damage or a criminal who seeks to exploit computer assets for financial gain.
- Another type of unwanted access is the placement in a computer system of logic that exploits vulnerabilities in the system.

Two-Layer Defense Strategy

Gatekeeper Functions (First Line)

- Password-based login procedures to deny access to unauthorized users
- Screening logic to detect and reject worms, viruses, and similar attacks
- Firewalls and proxy servers
- Network segmentation and isolation

Internal Controls (Second Line)

- Variety of internal controls that monitor activity
- Analyze stored information to detect unwanted intruders
- Host-based intrusion detection systems
- Log analysis and security monitoring

Eight Security Dimensions

Dimension	Implementation Techniques
Confidentiality	Encryption (AES, RSA, ECC), Access Control Lists, Data Classification, VPN, MPLS
Integrity	Hash Functions (MD5, SHA), Digital Signatures, Anti-virus software, File integrity checking
Authentication	Shared secret keys, PKI, Digital certificates, Multi-factor authentication
Access Control	Password policies, ACLs, Firewalls, Role-Based Access Control (RBAC)
Availability	IDS/IPS, Network redundancy, Business Continuity/Disaster Recovery (BC/DR)
Non-Repudiation	System logs, Digital signatures, Timestamping services, Audit trails
Privacy	Network Address Translation (NAT), Encryption, Anonymization techniques
Accountability	Logging systems, User activity monitoring, Forensic analysis tools

Mapping Dimensions to Threats

How Dimensions Address Vulnerabilities

Each security dimension addresses specific types of network vulnerabilities:

- **Confidentiality** Eavesdropping, data interception
- **Integrity** Data tampering, unauthorized modification
- **Authentication** Impersonation, identity spoofing
- **Access Control** Unauthorized access, privilege escalation
- **Availability** Denial of Service (DoS), system downtime
- **Non-Repudiation** Transaction repudiation, audit disputes
- **Privacy** Information leakage, user tracking
- **Accountability** Anonymous attacks, untraceable

Core Design Principles

1. Defense in Depth

Multiple layers of security controls:

- Network perimeter security
- Host hardening
- Application security
- Data encryption

2. Least Privilege

Minimum necessary permissions:

- Role-based access control
- Need-to-know basis
- Regular privilege reviews

4. Complete Mediation

- Every access must be checked
- No bypass mechanisms allowed
- Continuous authorization

5. Economy of Mechanism

- Simple, understandable designs
- Minimal trusted computing base
- Avoid unnecessary complexity

6. Open Design

- Security through transparency
- Peer review of implementations
- Use of standard algorithms

3. Fail-Safe Defaults

- Default deny policies
- Secure by default configurations
- Graceful degradation under attack

7. Separation of Duties

- Critical operations require multiple people
- Prevention of fraud and errors
- Cross-training and backup capabilities
- Dual control for sensitive operations

9. Work Factor

- Make attacks more costly than value gained
- Regular security updates and patches
- Monitor for new attack methods
- Security proportional to asset value

8. Psychological Acceptability

- Security shouldn't unduly hinder usability
- Intuitive security interfaces
- Clear security status feedback
- User training and awareness

10. Design for Acceptable Risk

- Identify assets and their values
- Assess threats and vulnerabilities
- Calculate risk levels
- Implement controls proportional to risk

Network Security Design Best Practices

- With all the variations of network security design, some important questions surface:
 - Identifying methods to reasonably secure components
 - Knowing when you've done enough to lock things down
 - Selecting the best design to maximize resilience
- There is no single answer that will suffice, but there are right ways and wrong ways to integrate security into a network.
- Regardless of size/complexity, three main factors constitute a secure & resilient network:
 - What you have (assets, systems)
 - Where it's located (network architecture)
 - How and when it's managed (operations)

Basic Practices for Network Security

Here are some basic practices for building network security systems:

- Understanding network threats and attack vectors
- Doing what is essential but nothing more (avoid over-engineering)
- Regular vulnerability assessment and penetration testing
- Follow layering approach (defense in depth)
- Use well-defined trust models and security zones
- Implement proper service operations and maintenance procedures
- Continuous monitoring and incident response planning

Key Principle: Keep It Simple

Complex security systems are harder to manage, maintain, and verify. Simplicity enhances security.

Threat Modeling Process

Systematic Approach to Security Design

- ➊ **Identify Assets:** What needs protection?
- ➋ **Create Architecture Overview:** System boundaries and data flows
- ➌ **Decompose Application:** Identify trust boundaries and components
- ➍ **Identify Threats:** Using methodologies like STRIDE
- ➎ **Document Threats:** Create comprehensive threat catalog
- ➏ **Rate Threats:** Assess using DREAD or similar approach
- ➐ **Mitigate Threats:** Design and implement countermeasures
- ➑ **Validate:** Test threat model effectiveness

Host Hardening Process

The Problem:

- Computers installed out of the box have known vulnerabilities
- Not just Windows computers - all operating systems
- Hackers can take them over easily
- They must be hardened a complex process involving many actions

Elements of Hardening:

- 1 Physical security measures
- 2 Secure installation and configuration
- 3 Fix known vulnerabilities (patching)
- 4 Turn off unnecessary services

- 5 Harden all remaining applications
- 6 Manage users and groups properly
- 7 Manage access permissions for files/directories
- 8 Assign permissions to specific users and groups
- 9 Back up the server regularly
- 10 Implement advanced protections (IDS, firewalls)

Regular Maintenance

- Continuous vulnerability assessment
- Regular security updates
- Log monitoring and analysis
- Security policy enforcement

Thank You

**Secure Models for Network Security
& Design Principles**

Questions?